

IdentityGuard

Zero-Trust Identity Threat Detection & Response

Detect identity threats before they become incidents.

Live Demo

identityguard-p9p1.onrender.com

Open Source

github.com/Debrajdutta-Developer/IdentityGuard

Author

Debraj Dutta, The Ghost

Most breaches start with a login that looks normal.

The identity perimeter is broken.

Stolen Credentials

Compromised passwords pass every traditional password check — the attacker looks exactly like the legitimate user. No signature, no flag, no friction.

Signal Buried in Noise

Failed attempts, new devices, and anomalous geolocations hide invisibly inside thousands of daily authentication events with no correlation engine to surface them.

Privilege Changes

Unauthorized user-to-admin transitions go unnoticed until damage is done. By then the attacker has already moved laterally.

No Evidence Chain

Without a durable audit trail, investigators have no decision-level reasoning to reconstruct the attack chain — compliance suffers, attribution fails.

❏ **Identity is the new perimeter.** Every access decision is an opportunity for detection — or a gap an adversary will exploit.

The solution: Risk intelligence, policy decisions, evidence.

Authentication telemetry becomes explainable risk decisions, security alerts, and auditable evidence.

Risk Intelligence

Correlates failed auth events, device novelty signals, travel anomalies, privilege change events, and session behavioral signals into a single **explainable composite risk score** — no black box, no guesswork.

Policy Decisions

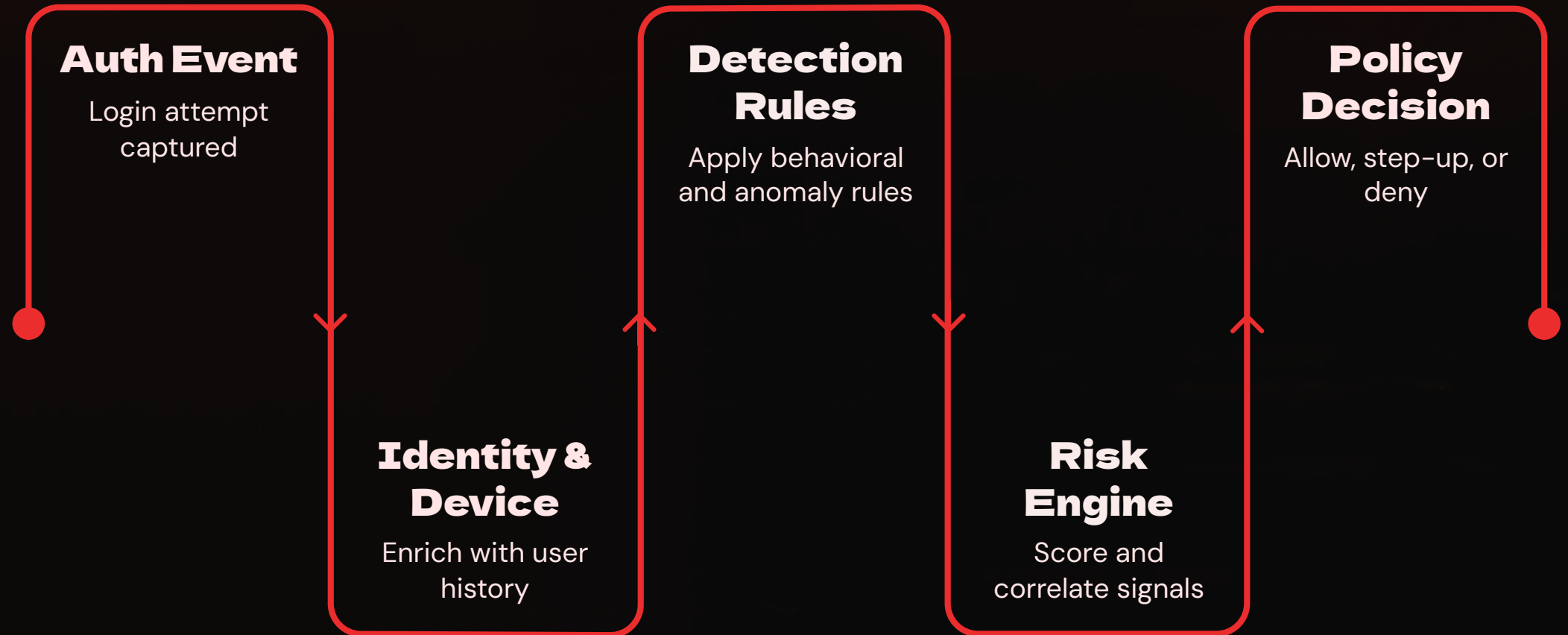
Explicit, threshold-driven outcomes: **Allow** for low-risk sessions, **Step-Up** MFA for medium-risk, **Deny** and alert for high or critical risk. Every outcome is deterministic and auditable.

Evidence Ledger

Durable, **tenant-scoped audit trail** persisted for every authentication decision — including the full reasoning, signal breakdown, and policy outcome — enabling compliance, forensics, and investigation.

How it works: The detection pipeline.

Seven-step flow from event to audit.



Every authentication event traverses all seven stages in sequence. The pipeline is stateless at the evaluation layer but writes durable state to PostgreSQL at the audit stage — ensuring both performance and compliance integrity.

Five core detection capabilities.

Catch identity threats across the full attack surface.



Repeated Failed Authentication

Detects brute force and credential stuffing campaigns by correlating sequential failed login attempts against velocity and pattern thresholds per identity.



New or Unrecognized Device

Flags sessions originating from hardware not previously associated with the identity — a strong signal for compromised or stolen credential use on attacker infrastructure.



Impossible-Travel Patterns

Computes distance-vs-time anomalies across sequential geolocations. Physically impossible travel velocity triggers an automatic high-risk signal with geographic evidence.



Privilege Escalation

Monitors for unauthorized user-to-admin role transitions. Any unplanned privilege change outside approved change windows is surfaced as a high-severity detection.



Suspicious Session Activity

Identifies behavioral deviations within authenticated sessions — anomalous access patterns, resource enumeration, and atypical interaction sequences that indicate post-authentication compromise.

Live dashboard: Real-time threat monitoring.

See detection in action across your identity infrastructure.

1,284

Auth Events

Authentication events monitored by the live backend

7

High-Risk Signals

Active high-risk detections surfaced by the risk engine

312

Identities in Scope

Unique identities currently under behavioral monitoring

 CRITICAL – Impossible Travel

user_104 · Risk Score: 85 · Cross-geography session detected; physically impossible transit time between authentication origins.

 HIGH – Privilege Escalation

admin_021 · Risk Score: 35 · Unauthorized role elevation detected outside approved change window.

 MEDIUM – New Device

user_087 · Risk Score: 25 · Authentication from unrecognized hardware not previously associated with this identity.

 Detection Engine: **ACTIVE** · Events are synthetic; all risk assessments are produced by the real deployed backend at identityguard-p9p1.onrender.com

Three decision outcomes: Allow, step-up, deny.

Every authentication decision is explainable and auditable.

✓ **ALLOW**

Condition: Known device · Successful authentication · Low composite risk score

Session proceeds without friction. Decision and supporting signals written to the audit ledger for baseline telemetry.

⚠ **STEP-UP**

Condition: Medium risk detected — device novelty, moderate anomaly score, or marginal behavioral deviation

Require MFA or additional verification before granting session. Outcome and reasoning logged with full signal breakdown.

✗ **DENY**

Condition: High or critical risk — impossible travel, confirmed privilege escalation, or brute-force threshold exceeded

Session blocked immediately. Security team alerted in real time. Complete forensic record written to the durable audit ledger.

Every decision is stored with its full reasoning in the audit ledger — enabling compliance reporting, incident investigation, and adversarial reconstruction without relying on log aggregation.

Architecture: Layered identity threat detection.

FastAPI backend · PostgreSQL · Redis · SPIFFE/SPIRE workload identity

API Layer – FastAPI Policy Boundary

`/health`

Liveness and readiness probe for the detection service

`/api/v1/events/evaluate`

Primary evaluation endpoint — accepts auth event, returns policy decision + risk score

`/api/v1/audit/events`

Retrieves tenant-scoped audit records with decision reasoning

`/api/v1/identity/workload`

Workload identity verification via SPIFFE/SPIRE agent

Data Layer – Durable State & Rate Control

PostgreSQL

Durable, tenant-scoped persistence for all audit events, decision records, and identity context history.

Redis

Distributed rate limiting and velocity tracking across authentication event streams in real time.

Identity Layer – SPIFFE/SPIRE

SPIFFE/SPIRE Agent · X.509-SVID · TLS 1.3 mTLS

Cryptographic workload identity with SPIFFE ID and mutual TLS boundary enforcement. *Note: Manually set SPIFFE ID is a development fallback only — not cryptographic proof.*

Security controls: Defense in depth.

Nine layers of protection for your identity infrastructure.

1 Tenant-Aware RBAC

Viewer and admin roles enforced at the API boundary — every request is scoped to its tenant context with no cross-tenant data leakage.

2 API-Key Authentication

Service-to-service access gated by API key validation at the policy boundary before any evaluation logic executes.

3 Persistent Audit Ledger

Every authentication event and policy decision written durably with full reasoning — supports compliance reporting and forensic reconstruction.

4 Request Rate Limiting

Redis-backed distributed rate limiting prevents API abuse, credential stuffing against the platform itself, and resource exhaustion attacks.

5 Trusted-Host Validation & CORS

Restricted CORS policy and trusted-host enforcement prevent cross-origin abuse and unauthorized API surface exposure.

Security Response Headers

HSTS enforcement and hardened HTTP response headers across all endpoints.

Optional SPIFFE/SPIRE

Cryptographic workload identity for service-to-service mTLS in production deployments.

Automated CI Testing

Pytest-based test suite runs on every commit — security regressions caught before deployment.

Get started: Run locally in minutes.

MVP / research-ready architecture · Authorized defensive security monitoring and research only.

Setup in 3 Commands

```
python -m venv .venv
pip install -r requirements.txt
uvicorn app.main:app --reload
```

Then open `/docs` for the interactive API explorer — full Swagger UI with live request/response testing against your local backend.

Resources

Live Demo

identityguard-
p9p1.onrender.com/#top

GitHub Repo

github.com/Debrajdutta-
Developer/IdentityGuard

Contribute

Feedback, issues, and PRs welcome. This is an open-source project built for the defensive security community.

CYBERSECURITY

ZERO-TRUST

IDENTITY SECURITY

SECURITY AUTOMATION

Debraj Dutta, The Ghost